

A **cyber attack** is any type of offensive action that targets computer information systems, infrastructures, computer networks or personal computer devices, using various methods to steal, alter or destroy data or information systems.

Today I'll describe the 10 most common cyber attack types:

1. [Denial-of-service \(DoS\) and distributed denial-of-service \(DDoS\) attacks](#)
2. [Man-in-the-middle \(MitM\) attack](#)
3. [Phishing and spear phishing attacks](#)
4. [Drive-by attack](#)
5. [Password attack](#)
6. [SQL injection attack](#)
7. [Cross-site scripting \(XSS\) attack](#)
8. [Eavesdropping attack](#)
9. [Birthday attack](#)
10. [Malware attack](#)

Handpicked related content:

- [Network Security Best Practices](#)

1. Denial-of-service (DoS) and distributed denial-of-service (DDoS) attacks

A denial-of-service attack overwhelms a system's resources so that it cannot respond to service requests. A DDoS attack is also an attack on system's resources, but it is launched from a large number of other host machines that are infected by malicious software controlled by the attacker.

Unlike attacks that are designed to enable the attacker to gain or increase access, denial-of-service doesn't provide direct benefits for attackers. For some of them, it's enough to have the satisfaction of service denial. However, if the attacked resource belongs to a business competitor, then the benefit to the attacker may be real enough. Another purpose of a DoS attack can be to take a system offline so that a different kind of attack can be launched. One common example is session hijacking, which I'll describe later.

There are different types of DoS and DDoS attacks; the most common are TCP SYN flood attack, teardrop attack, smurf attack, ping-of-death attack and botnets.

TCP SYN flood attack

In this attack, an attacker exploits the use of the buffer space during a Transmission Control Protocol (TCP) session initialization handshake. The attacker's device floods the target system's small in-process queue with connection requests, but it does not respond when the target system replies to those requests. This causes the target system to time out while waiting for the

response from the attacker's device, which makes the system crash or become unusable when the connection queue fills up.

There are a few countermeasures to a TCP SYN flood attack:

- Place servers behind a firewall configured to stop inbound SYN packets.
- Increase the size of the connection queue and decrease the timeout on open connections.

Teardrop attack

This attack causes the length and fragmentation offset fields in sequential Internet Protocol (IP) packets to overlap one another on the attacked host; the attacked system attempts to reconstruct packets during the process but fails. The target system then becomes confused and crashes.

If users don't have patches to protect against this DoS attack, disable SMBv2 and block ports 139 and 445.

Smurf attack

This attack involves using IP spoofing and the ICMP to saturate a target network with traffic. This attack method uses ICMP echo requests targeted at broadcast IP addresses. These ICMP requests originate from a spoofed "victim" address. For instance, if the intended victim address is 10.0.0.10, the attacker would spoof an ICMP echo request from 10.0.0.10 to the broadcast address 10.255.255.255. This request would go to all IPs in the range, with all the responses going back to 10.0.0.10, overwhelming the network. This process is repeatable, and can be automated to generate huge amounts of network congestion.

To protect your devices from this attack, you need to disable IP-directed broadcasts at the routers. This will prevent the ICMP echo broadcast request at the network devices. Another option would be to configure the end systems to keep them from responding to ICMP packets from broadcast addresses.

Ping of death attack

This type of attack uses IP packets to 'ping a target system with an IP size over the maximum of 65,535 bytes. IP packets of this size are not allowed, so attacker fragments the IP packet. Once the target system reassembles the packet, it can experience buffer overflows and other crashes.

Ping of death attacks can be blocked by using a firewall that will check fragmented IP packets for maximum size.

Botnets

Botnets are the millions of systems infected with malware under hacker control in order to carry out DDoS attacks. These bots or zombie systems are used to carry out attacks against the target systems, often overwhelming the target system's bandwidth and processing capabilities. These DDoS attacks are difficult to trace because botnets are located in differing geographic locations.

Botnets can be mitigated by:

- RFC3704 filtering, which will deny traffic from spoofed addresses and help ensure that traffic is traceable to its correct source network. For example, RFC3704 filtering will drop packets from bogon list addresses.
- Black hole filtering, which drops undesirable traffic before it enters a protected network. When a DDoS attack is detected, the BGP (Border Gateway Protocol) host should send routing updates to ISP routers so that they route all traffic heading to victim servers to a null0 interface at the next hop.

2. Man-in-the-middle (MitM) attack

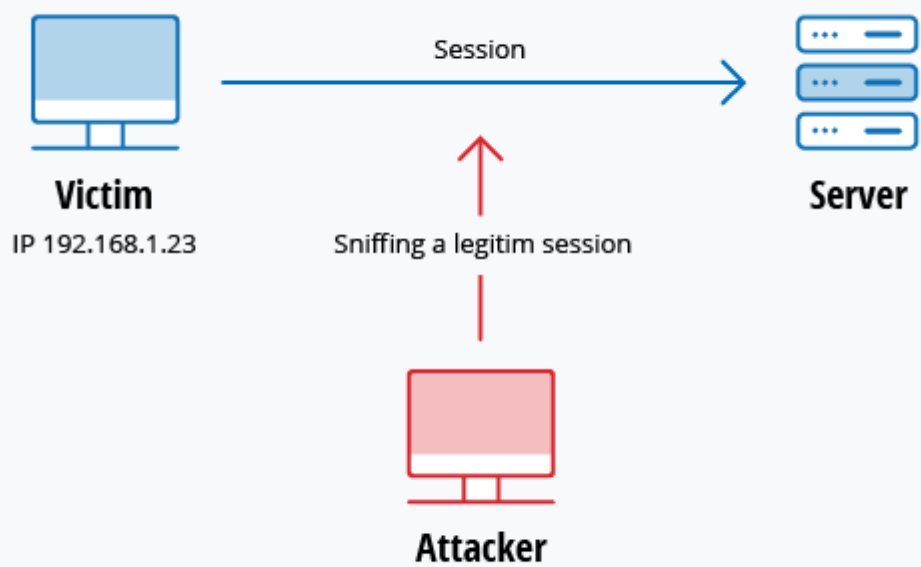
A MitM attack occurs when a hacker inserts itself between the communications of a client and a server. Here are some common types of man-in-the-middle attacks:

Session hijacking

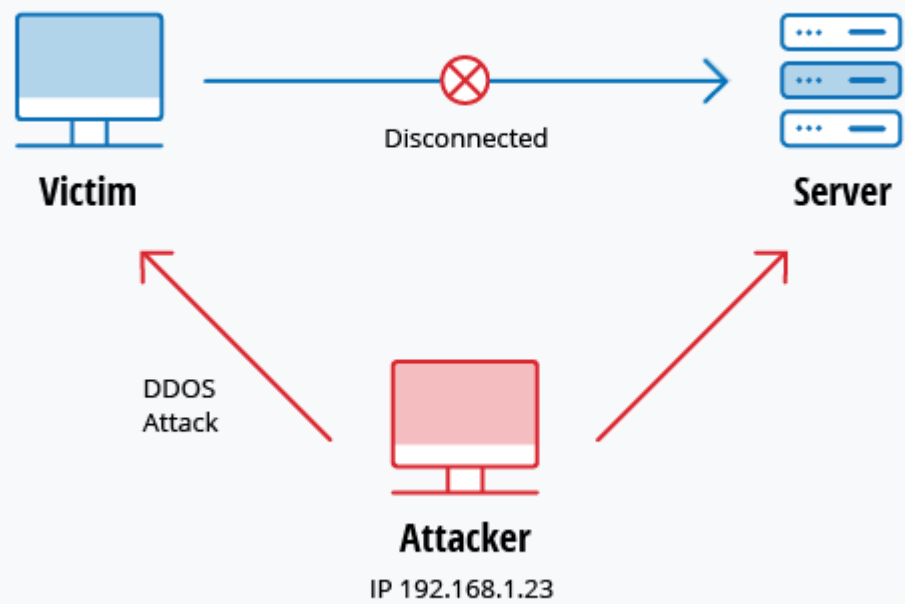
In this type of MitM attack, an attacker hijacks a session between a trusted client and network server. The attacking computer substitutes its IP address for the trusted client while the server continues the session, believing it is communicating with the client. For instance, the attack might unfold like this:

1. A client connects to a server.
2. The attacker's computer gains control of the client.
3. The attacker's computer disconnects the client from the server.
4. The attacker's computer replaces the client's IP address with its own IP address and spoofs the client's sequence numbers.
5. The attacker's computer continues dialog with the server and the server believes it is still communicating with the client.

1



2



IP Spoofing

IP spoofing is used by an attacker to convince a system that it is communicating with a known, trusted entity and provide the attacker with access to the system. The attacker sends a packet with the IP source address of a known, trusted host instead of its own IP source address to a target host. The target host might accept the packet and act upon it.

Replay

A replay attack occurs when an attacker intercepts and saves old messages and then tries to send them later, impersonating one of the participants. This type can be easily countered with session timestamps or nonce (a random number or a string that changes with time).

Currently, there is no single technology or configuration to prevent all MitM attacks. Generally, encryption and digital certificates provide an effective safeguard against MitM attacks, assuring both the confidentiality and integrity of communications. But a man-in-the-middle attack can be injected into the middle of communications in such a way that encryption will not help — for example, attacker “A” intercepts public key of person “P” and substitute it with his own public key. Then, anyone wanting to send an encrypted message to P using P’s public key is unknowingly using A’s public key. Therefore, A can read the message intended for P and then send the message to P, encrypted in P’s real public key, and P will never notice that the message was compromised. In addition, A could also modify the message before resending it to P. As you can see, P is using encryption and thinks that his information is protected but it is not, because of the MitM attack.

So, how can you make sure that P’s public key belongs to P and not to A? Certificate authorities and hash functions were created to solve this problem. When person 2 (P2) wants to send a message to P, and P wants to be sure that A will not read or modify the message and that the message actually came from P2, the following method must be used:

1. P2 creates a symmetric key and encrypts it with P’s public key.
2. P2 sends the encrypted symmetric key to P.
3. P2 computes a hash function of the message and digitally signs it.
4. P2 encrypts his message and the message’s signed hash using the symmetric key and sends the entire thing to P.
5. P is able to receive the symmetric key from P2 because only he has the private key to decrypt the encryption.
6. P, and only P, can decrypt the symmetrically encrypted message and signed hash because he has the symmetric key.
7. He is able to verify that the message has not been altered because he can compute the hash of received message and compare it with digitally signed one.
8. P is also able to prove to himself that P2 was the sender because only P2 can sign the hash so that it is verified with P2 public key.

3. Phishing and spear phishing attacks

Phishing attack is the practice of sending emails that appear to be from trusted sources with the goal of gaining personal information or influencing users to do something. It combines social engineering and technical trickery. It could involve an attachment to an email that loads malware onto your computer. It could also be a link to an illegitimate website that can trick you into downloading malware or handing over your personal information.

Spear phishing is a very targeted type of phishing activity. Attackers take the time to conduct research into targets and create messages that are personal and relevant. Because of this, spear phishing can be very hard to identify and even harder to defend against. One of the simplest ways that a hacker can conduct a spear phishing attack is email spoofing, which is when the information in the “From” section of the email is falsified, making it appear as if it is coming from someone you know, such as your management or your partner company. Another technique that scammers use to add credibility to their story is website cloning — they copy legitimate websites to fool you into entering personally identifiable information (PII) or login credentials.

To reduce the risk of being phished, you can use these techniques:

- **Critical thinking** — Do not accept that an email is the real deal just because you're busy or stressed or you have 150 other unread messages in your inbox. Stop for a minute and analyze the email.
- **Hovering over the links** — Move your mouse over the link, but **do not click it!** Just let your mouse cursor hover over the link and see where it would actually take you. Apply critical thinking to decipher the URL.
- **Analyzing email headers** — Email headers define how an email got to your address. The “Reply-to” and “Return-Path” parameters should lead to the same domain as is stated in the email.
- **Sandboxing** — You can test email content in a sandbox environment, logging activity from opening the attachment or clicking the links inside the email.

4. Drive-by attack

Drive-by download attacks are a common method of spreading malware. Hackers look for insecure websites and plant a malicious script into HTTP or PHP code on one of the pages. This script might install malware directly onto the computer of someone who visits the site, or it might re-direct the victim to a site controlled by the hackers. Drive-by downloads can happen when visiting a website or viewing an email message or a pop-up window. Unlike many other types of cyber security attacks, a drive-by doesn't rely on a user to do anything to actively enable the attack — you don't have to click a download button or open a malicious email attachment to become infected. A drive-by download can take advantage of an app, operating system or web browser that contains security flaws due to unsuccessful updates or lack of updates.

To protect yourself from drive-by attacks, you need to keep your browsers and operating systems up to date and avoid websites that might contain malicious code. Stick to the sites you normally use — although keep in mind that even these sites can be hacked. Don't keep too

many unnecessary programs and apps on your device. The more plug-ins you have, the more vulnerabilities there are that can be exploited by drive-by attacks.

5. Password attack

Because passwords are the most commonly used mechanism to authenticate users to an information system, obtaining passwords is a common and effective attack approach. Access to a person's password can be obtained by looking around the person's desk, "sniffing" the connection to the network to acquire unencrypted passwords, using social engineering, gaining access to a password database or outright guessing. The last approach can be done in either a random or systematic manner:

- **Brute-force** password guessing means using a random approach by trying different passwords and hoping that one work. Some logic can be applied by trying passwords related to the person's name, job title, hobbies or similar items.
- In a **dictionary attack**, a dictionary of common passwords is used to attempt to gain access to a user's computer and network. One approach is to copy an encrypted file that contains the passwords, apply the same encryption to a dictionary of commonly used passwords, and compare the results.

In order to protect yourself from dictionary or brute-force attacks, you need to implement an account lockout policy that will lock the account after a few invalid password attempts. You can follow these [account lockout best practices](#) in order to set it up correctly.

Handpicked related content:

- [Password Policy Best Practices](#)

6. SQL injection attack

SQL injection has become a common issue with database-driven websites. It occurs when a malefactor executes a SQL query to the database via the input data from the client to server. SQL commands are inserted into data-plane input (for example, instead of the login or password) in order to run predefined SQL commands. A successful SQL injection exploit can read sensitive data from the database, modify (insert, update or delete) database data, execute administration operations (such as shutdown) on the database, recover the content of a given file, and, in some cases, issue commands to the operating system.

For example, a web form on a website might request a user's account name and then send it to the database in order to pull up the associated account information using dynamic SQL like this:

```
"SELECT * FROM users WHERE account = "" + userProvidedAccountNumber + "";"
```

While this works for users who are properly entering their account number, it leaves a hole for attackers. For example, if someone decided to provide an account number of “ or ‘1’ = ‘1’”, that would result in a query string of:

```
“SELECT * FROM users WHERE account = ” or ‘1’ = ‘1’;”
```

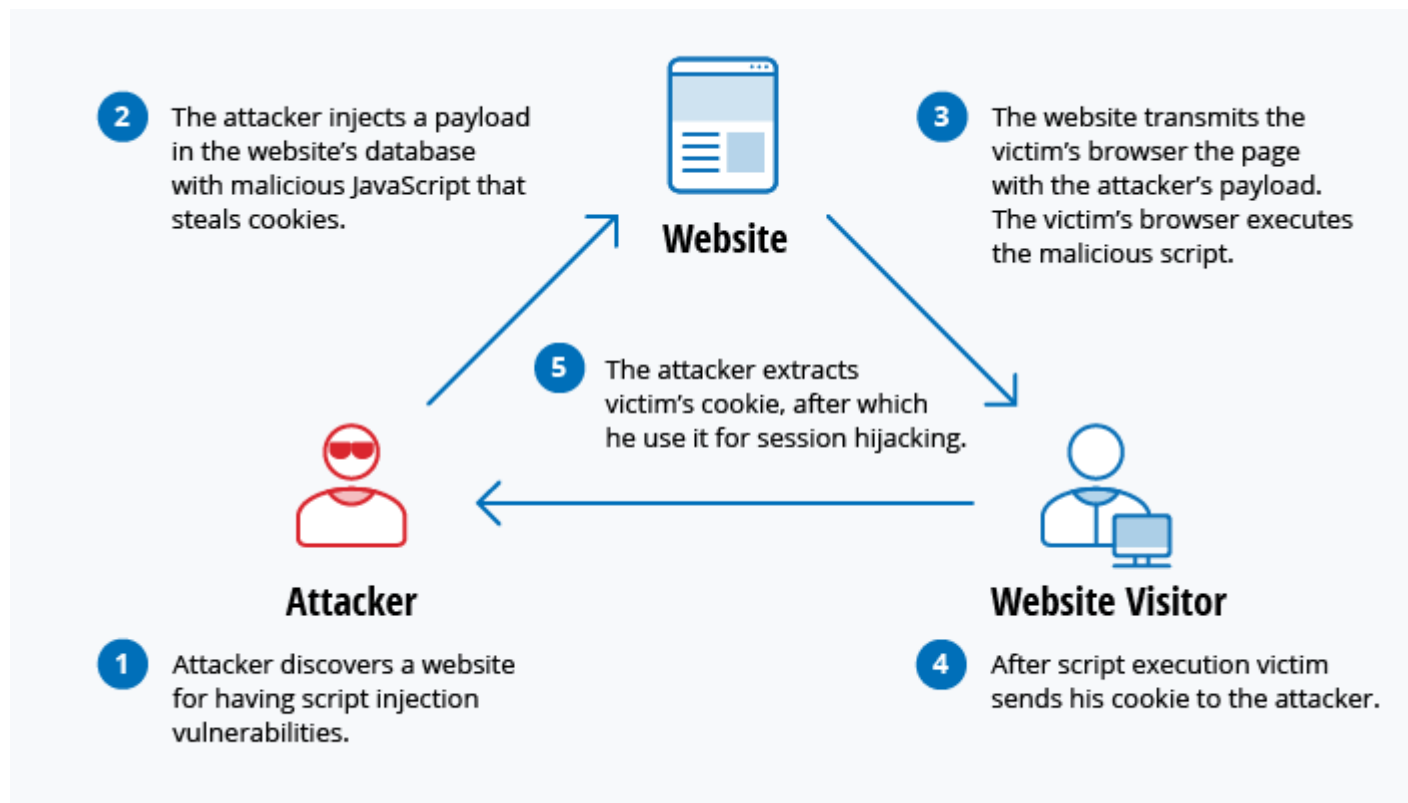
Because ‘1’ = ‘1’ always evaluates to TRUE, the database will return the data for all users instead of just a single user.

The vulnerability to this type of cyber security attack depends on the fact that SQL makes no real distinction between the control and data planes. Therefore, SQL injections work mostly if a website uses dynamic SQL. Additionally, SQL injection is very common with PHP and ASP applications due to the prevalence of older functional interfaces. J2EE and ASP.NET applications are less likely to have easily exploited SQL injections because of the nature of the programmatic interfaces available.

In order to protect yourself from a SQL injection attacks, apply least0privilege model of permissions in your databases. Stick to stored procedures (make sure that these procedures don’t include any dynamic SQL) and prepared statements (parameterized queries). The code that is executed against the database must be strong enough to prevent injection attacks. In addition, validate input data against a white list at the application level.

7. Cross-site scripting (XSS) attack

XSS attacks use third-party web resources to run scripts in the victim’s web browser or scriptable application. Specifically, the attacker injects a payload with malicious JavaScript into a website’s database. When the victim requests a page from the website, the website transmits the page, with the attacker’s payload as part of the HTML body, to the victim’s browser, which executes the malicious script. For example, it might send the victim’s cookie to the attacker’s server, and the attacker can extract it and use it for session hijacking. The most dangerous consequences occur when XSS is used to exploit additional vulnerabilities. These vulnerabilities can enable an attacker to not only steal cookies, but also log key strokes, capture screenshots, discover and collect network information, and remotely access and control the victim’s machine.



While XSS can be taken advantage of within VBScript, ActiveX and Flash, the most widely abused is JavaScript — primarily because JavaScript is supported widely on the web.

To defend against XSS attacks, developers can sanitize data input by users in an HTTP request before reflecting it back. Make sure all data is validated, filtered or escaped before echoing anything back to the user, such as the values of query parameters during searches. Convert special characters such as ?, &, /, <, > and spaces to their respective HTML or URL encoded equivalents. Give users the option to disable client-side scripts.

8. Eavesdropping attack

Eavesdropping attacks occur through the interception of network traffic. By eavesdropping, an attacker can obtain passwords, credit card numbers and other confidential information that a user might be sending over the network. Eavesdropping can be passive or active:

- **Passive eavesdropping** — A hacker detects the information by listening to the message transmission in the network.
- **Active eavesdropping** — A hacker actively grabs the information by disguising himself as friendly unit and by sending queries to transmitters. This is called probing, scanning or tampering.

Detecting passive eavesdropping attacks is often more important than spotting active ones, since active attacks requires the attacker to gain knowledge of the friendly units by conducting passive eavesdropping before.

Data encryption is the best countermeasure for eavesdropping.

9. Birthday attack

Birthday attacks are made against hash algorithms that are used to verify the integrity of a message, software or digital signature. A message processed by a hash function produces a message digest (MD) of fixed length, independent of the length of the input message; this MD uniquely characterizes the message. The birthday attack refers to the probability of finding two random messages that generate the same MD when processed by a hash function. If an attacker calculates same MD for his message as the user has, he can safely replace the user's message with his, and the receiver will not be able to detect the replacement even if he compares MDs.

10. Malware attack

Malicious software can be described as unwanted software that is installed in your system without your consent. It can attach itself to legitimate code and propagate; it can lurk in useful applications or replicate itself across the Internet. Here are some of the most common types of malware:

- **Macro viruses** — These viruses infect applications such as Microsoft Word or Excel. Macro viruses attach to an application's initialization sequence. When the application is opened, the virus executes instructions before transferring control to the application. The virus replicates itself and attaches to other code in the computer system.
- **File infectors** — File infector viruses usually attach themselves to executable code, such as .exe files. The virus is installed when the code is loaded. Another version of a file infector associates itself with a file by creating a virus file with the same name, but an .exe extension. Therefore, when the file is opened, the virus code will execute.
- **System or boot-record infectors** — A boot-record virus attaches to the master boot record on hard disks. When the system is started, it will look at the boot sector and load the virus into memory, where it can propagate to other disks and computers.
- **Polymorphic viruses** — These viruses conceal themselves through varying cycles of encryption and decryption. The encrypted virus and an associated mutation engine are initially decrypted by a decryption program. The virus proceeds to infect an area of code. The mutation engine then develops a new decryption routine and the virus encrypts the mutation engine and a copy of the virus with an algorithm corresponding to the new decryption routine. The encrypted package of mutation engine and virus is attached to new code, and the process repeats. Such viruses are difficult to detect but have a high level of entropy because of the many modifications of their source code. Anti-virus software or free tools like Process Hacker can use this feature to detect them.
- **Stealth viruses** — Stealth viruses take over system functions to conceal themselves. They do this by compromising malware detection software so that the software will

report an infected area as being uninfected. These viruses conceal any increase in the size of an infected file or changes to the file's date and time of last modification.

- **Trojans** — A Trojan or a Trojan horse is a program that hides in a useful program and usually has a malicious function. A major difference between viruses and Trojans is that Trojans do not self-replicate. In addition to launching attacks on a system, a Trojan can establish a back door that can be exploited by attackers. For example, a Trojan can be programmed to open a high-numbered port so the hacker can use it to listen and then perform an attack.
- **Logic bombs** — A logic bomb is a type of malicious software that is appended to an application and is triggered by a specific occurrence, such as a logical condition or a specific date and time.
- **Worms** — Worms differ from viruses in that they do not attach to a host file, but are self-contained programs that propagate across networks and computers. Worms are commonly spread through email attachments; opening the attachment activates the worm program. A typical worm exploit involves the worm sending a copy of itself to every contact in an infected computer's email address. In addition to conducting malicious activities, a worm spreading across the internet and overloading email servers can result in denial-of-service attacks against nodes on the network.
- **Droppers** — A dropper is a program used to install viruses on computers. In many instances, the dropper is not infected with malicious code and, therefore might not be detected by virus-scanning software. A dropper can also connect to the internet and download updates to virus software that is resident on a compromised system.
- **Ransomware** — Ransomware is a type of malware that blocks access to the victim's data and threatens to publish or delete it unless a ransom is paid. While some simple computer ransomware can lock the system in a way that is not difficult for a knowledgeable person to reverse, more advanced malware uses a technique called cryptoviral extortion, which encrypts the victim's files in a way that makes them nearly impossible to recover without the decryption key.

Handpicked related content:

- [How to Prevent Ransomware Best Practices](#)
- [Ransomware Protection Using FSRM and PowerShell](#)
- [Ransomware Survivor: 6 Tips to Prevent Ransomware Attacks](#)
- **Adware** — Adware is a software application used by companies for marketing purposes; advertising banners are displayed while any program is running. Adware can be automatically downloaded to your system while browsing any website and can be viewed through pop-up windows or through a bar that appears on the computer screen automatically.
- **Spyware** — Spyware is a type of program that is installed to collect information about users, their computers or their browsing habits. It tracks everything you do without your knowledge and sends the data to a remote user. It also can download and install other malicious programs from the internet. Spyware works like adware but is usually a separate program that is installed unknowingly when you install another freeware application.

Conclusion

Mounting a good defense requires understanding the offense. This article has reviewed the 10 most common cyber-security attacks that hackers use to disrupt and compromise information systems. As you can see, attackers have many options, such as DDoS assaults, malware infection, man-in-the-middle interception, and brute-force password guessing, to trying to gain unauthorized access to critical infrastructures and sensitive data.

Measures to mitigate these threats vary, but security basics stay the same: Keep your systems and anti-virus databases up to date, train your employees, configure your firewall to whitelist only the specific ports and hosts you need, keep your passwords strong, use a least-privilege model in your IT environment, make regular backups, and continuously audit your IT systems for suspicious activity.

3. Security Issues in IoT

3.1. Security Services

As previously mentioned, the use of connecting objects in everyday people's lives can make security issues life-threatening. The smartness integrated into homes, cars, and electric grids can be diverted into harmful scenarios when exploited by hackers. Different hacking scenarios presented in the past years [23,24] illustrate the level of harm that could result from a security breach, especially with the development and large adoption of IoT applications dealing with sensitive information (personal, industrial, governmental, etc.).

The main IoT security concerns are: authentication, authorization, integrity, confidentiality, non-repudiation, Availability, and privacy [25,26,27].

1. *Authentication*: The process of confirming and insuring the identity of objects. In IoT context, each object should have the ability to identify and authenticate all other objects in the system (or in a given part of the system with which it interacts).
2. *The authorization*: The process of giving permission to an entity to do or have something [28].
3. *Integrity*: The way toward keeping up the consistency, precision and dependability of information over its whole life cycle. In IoT, the alteration of basic information or even the infusion of invalid information could prompt major issues, e.g., in smart health systems use cases it could lead to the death of the patient [29].
4. *Confidentiality*: The process of ensuring that the information is only accessed by authorized people. Two main issues should be considered [27] regarding confidentiality in IoT: firstly, to ensure that the object receiving the data is not going

to move/transfer these data to other objects and, secondly, to consider the data management.

5. *Non-repudiation*: The way toward guaranteeing the ability to demonstrate that a task or event has occurred (and by whom), with the goal that this cannot be denied later. In other words, the object cannot deny the authenticity of a specific data transferred.
6. *Availability*: The process of ensuring that the service needed is available anywhere and anytime for the intended users. This includes in IoT, the availability of the objects themselves.
7. *Privacy*: The process of ensuring non-accessibility to private information by public or malicious objects [30].

3.2. Security Challenges in IoT Layers

In this section, we consider the most basic architecture of IoT (three-layer architecture), and discuss the security concerns, attacks and security requirements at each layer of the architecture.

3.2.1. Perception Layer Security Issues and Requirements

The perception layer consists of sensors that are characterized by limited processing power and storage capacity [31]. Several security issues and attack risks rise due to such limitations.

Several attacks on the perception layer are noticed:

1. *Node Capture*: Nodes (base node or gateway) can be easily controlled by the attackers. Catching a node empowers an adversary not only to get tightly of cryptographic keys and protocol states, but also to clone and redistribute malicious nodes in the network, which affects the security of the entire network [32,33].
2. *Denial of Service (DoS) Attack*: A type of attacks that shuts down the system or network and prevents authorized users from accessing it. This could be achieved by overwhelming the system or network with large amount of spam requests all at the same time, thus overloading the system and preventing it from delivering the normal service [34].
3. *Denial of Sleep Attack*: One of the essential objective of an IoT network is the capability of sensing through an extensive number of distributed nodes, each providing small data, such as temperature, humidity, vibration, etc. at a set interval and then going to sleep for another time interval in order to allow the nodes to operate for long service life. The denial of sleep attack works on the power supply of the node with a significant goal to increase the power consumption in order to reduce the service lifetime of the node by preventing the node from going asleep after sending the appropriate sensed data [35,36].

4. *Distributed Denial of Service (DDoS) Attack*: A large scale variant of DoS attacks. The most challenging issue is the ability to use the large amount of IoT nodes to pass traffic collected toward the victim server [37,38]. There are indications that the DDoS attack called “Mirai” [5,6] occurring on October 2016 benefited from a large number of IoT nodes.
5. *Fake Node/Sybil Attack*: A type of attacks where the attacker can deploy fake identities using fake nodes. With the presence of a sybil node, the whole system might generate wrong data or even the neighbor nodes will receive spam data and will mislay their privacy [39,40]. The fake nodes could be used to transmit data to “legitimate” nodes leading them to consume their energy, which could lead the whole service to go down.
6. *Replay Attack*: In this attack, information is stored and re-transmitted later without having the authority to do that. Such attacks are commonly used against authentication protocols [41,42].
7. *Routing Threats*: This type of attacks is the most fundamental attack at the network layer but it could occur at the perception layer in data forwarding process. An attacker can create a routing loop causing the shortage or extension of the routing path, increasing the end-to-end delay, and increasing the error messages [43].
8. *Side-Channel Attack*: This type of attacks occurs on encryption devices by taking advantage of the hardware information where the crypto-system is applied on (chips), such as the execution time, power consumption, power dissipation, and electromagnetic interference produced by electronic devices throughout the encryption procedure. Such information could be analyzed to discover secret keys used during the encryption process [44,45,46,47].
9. *Mass Node Authentication*: The process of authenticating large amount of devices in an IoT system, which requires massive amount of network communication for the authentication phase to finish and this could affect the performance of the whole system.

Taking into consideration the above-mentioned risks, there is a need for node authentication to prevent fake node and illegal access, in addition to the need for data encryption to protect the confidentiality of data while being transmitted between nodes (end node, gateway or server). Due to the properties of the nodes with respect to the shortage of power and the limited storage capacity, there is a necessity for mature lightweight security schemes that include both lightweight cryptographic algorithms and security protocols.

3.2.2. Network Layer Security Issues and Requirements

The network layer is in charge of the diffusion of data from the perception layer to the application layer. This is where data routing occurs as well as the primary data analysis. In this layer, several network technologies are used such as the different technologies for

mobile communication generations (2G, 3G, 4G and 5G) and wireless networks (Bluetooth, WiMAX, WiFi, LoRaWAN, etc.).

Several attacks and risks on the network layer are identified:

1. *Man-in-the-Middle (MITM)*: According to McAfee [6], the most recurrent attacks are Denial of Service (DoS) and Man In the Browser (MITB) attacks. This latter, along with the Secure Socket Layer (SSL) attack, which enables attackers to listen to traffic, intercept it, and spoof both ends of the data, constitute the MITM attack [48,49].
2. *Denial of Service (DoS)*: This type of attacks occurs also at the network layer by jamming the transmission of radio signals, using a fake node, affecting the transmission or routing of data between nodes [50,51].
3. *Eavesdropping/sniffing*: This type of passive attacks gives the intruder the ability to listen to the private communication over the communication link [52]. The intruder might be able to extract useful information such as usernames and passwords, node identification or node configuration, which could lead to other types of attacks, e.g., fake node, replay attack, etc.
4. *Routing attacks*: This type of attacks affects how the messages or data are routed. The intruder spoofs, redirects, misdirects or even drops packets at the network layer. The following specific attacks could be considered:

○ (a)

Black Hole: It can also be considered as a DoS attack, in which the intruder uses a fake node that welcomes all traffic by asserting that it has the shortest path. As a result, all traffic will be redirected to the fake node that has the ability to redirect them to a proxy server or even drop them [53].

○ (b)

Gray Hole: This type of attacks is similar to the black hole attack but instead of dropping all the packets, it only drops selected ones [54,55].

○ (c)

Worm Hole: In this type of attacks, the intruder creates a connection between two points in the network by either controlling at least two nodes of the network or adding new fake nodes to the network. After forming the link, the intruder collects data from one end and replays them to the other end [56,57].

○ (d)

Hello Flood: The aim of the attacker in this type of attacks is to consume the power of nodes in the system by broadcasting Hello request packets by a fake

node to influence all the nodes in the system that they are in the same range, thus causing each one to send packets to its neighbor causing a huge traffic in the network [58,59,60]. (hello messages are defined in some routing protocols, so that nodes announce themselves to their neighbors.)

○ (e)

Sybil: In this attack, a fake node presents multiple identities, thus it can control a considerable part of the framework by being in different places within the network at the same time. When many sybil nodes are within the same network, they will then send a large amount of information denying the normal nodes from using the network [61].

These potential attacks at the network layer (wired or wireless) lead to the definition of the following security requirements: hop-to-hop encryption, point-to-point authentication, key agreement and management, security routing and intrusion detection [62].

3.2.3. Application Layer Security Issues and Requirements

The application layer is responsible for providing services. It hosts a set of protocols for message passing [19,63], e.g., Constrained Application Protocol (COAP), Message Queuing Telemetry Transport (MQTT), Extensible Messaging and Presence Protocol (XMPP), Advanced Message Queuing Protocol (AMQP), etc. This layer directly interacts with the user. Given that the “traditional” application-layer protocols do not perform well within IoT, and since the IoT does not have its own international standards, several security issues arise at the application layer [27].

1. *Data Accessibility and Authentication*: Each application might have many users [64]. Fake or illegal users could have a great impact on the availability of the whole system. Such great number of users means different permission and access control.
2. *Data privacy and identity*: The fact that IoT connects different devices from different manufacturers leads to the application of different authentication schemes. The integration of these schemes is a challenging issue to ensure data privacy and identity.
3. *Dealing with the Availability of Big data*: IoT connects a huge number of end devices, which leads to a huge amount of data to be managed. This causes an overhead on the application to analyze this data, which has a big impact on the availability of the service(s) provided by the application.

Regarding the security requirements for the application layer, authentication is required while protecting the privacy of users (respectively, data). In addition, there should be an information security management scheme that includes resource management and physical security information management. Table 1 gives a summary of the security requirements of the three-layers in the IoT architecture.

Table 1

IoT Architecture and security requirements.

Layer	Security Requirements
Perception	Lightweight Encryption
	Authentication
	Key Agreement
	Data Confidentiality
	Communication Security
Network	Routing Security
	Authentication
	Key Management
	Intrusion Detection

Layer	Security Requirements
	Authentication
Application	Privacy protection
	Information Security Management

Have you ever found yourself waiting impatiently for the online release of a product, one that you're eagerly waiting to purchase? You keep refreshing the page, waiting for that moment when the product will go live. Then, as you press F5 for the last time, the page shows an error: "Service Unavailable." The server must be overloaded!

There are indeed cases like these where a website's server gets overloaded with traffic and simply crashes, sometimes when a news story breaks. But more commonly, this is what happens to a website during a DoS attack, or denial-of-service, a malicious traffic overload that occurs when attackers flood a website with traffic. When a website has too much traffic, it's unable to serve its content to visitors.

A DoS attack is performed by one machine and its internet connection, by flooding a website with packets and making it impossible for legitimate users to access the content of flooded website. Fortunately, you can't really

overload a server with a single other server or a PC anymore. In the past years it hasn't been that common if anything, then by flaws in the protocol.

A DDoS attack, or distributed denial-of-service attack, is similar to DoS, but is more forceful. It's harder to overcome a DDoS attack. It's launched from several computers, and the number of computers involved can range from just a couple of them to thousands or even more.

Since it's likely that not all of those machines belong to the attacker, they are compromised and added to the attacker's network by malware. These computers can be distributed around the entire globe, and that network of compromised computers is called botnet.

Since the attack comes from so many different IP addresses simultaneously, a DDoS attack is much more difficult for the victim to locate and defend against.

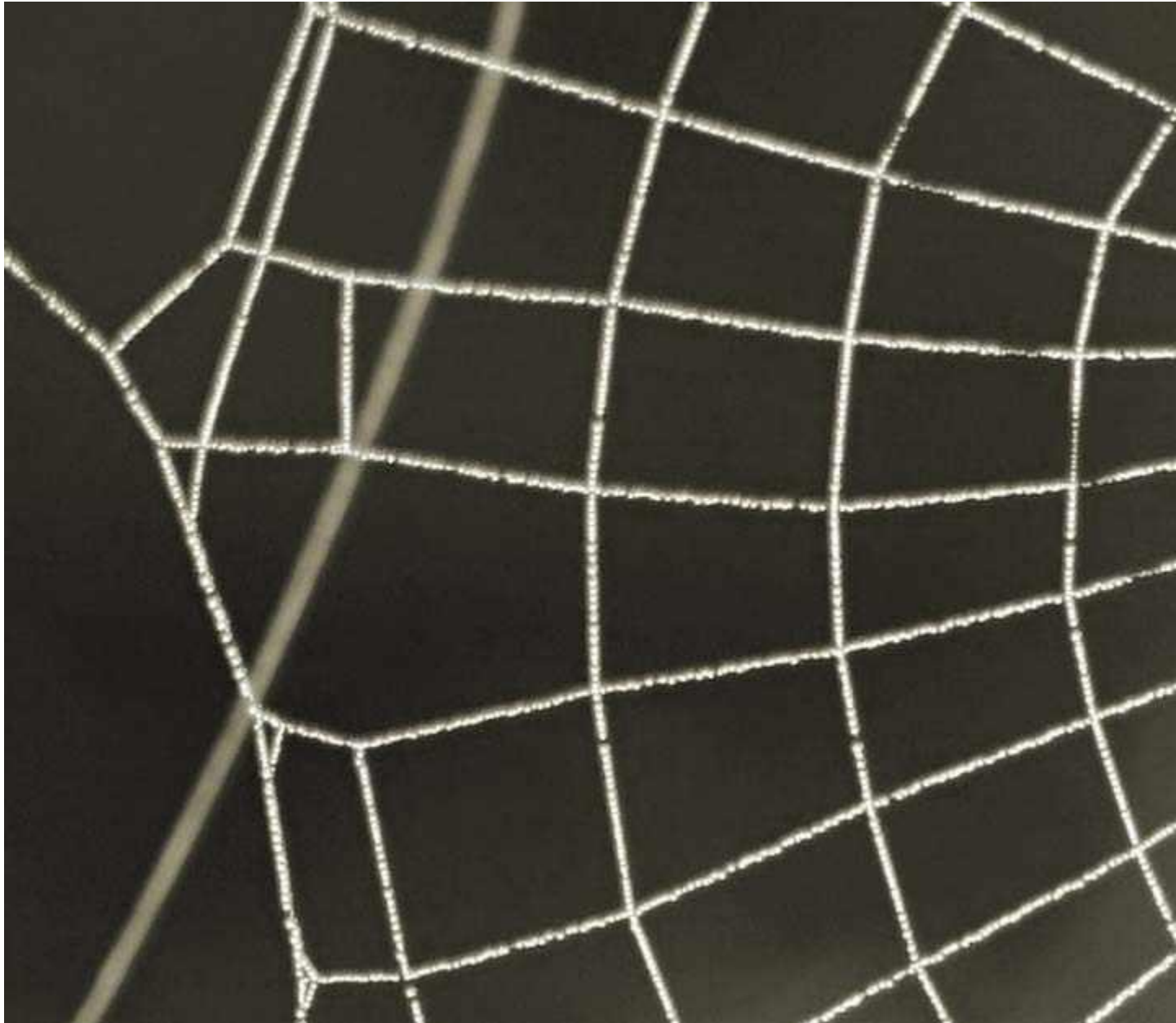
Phishing is a method of a social engineering with the goal of obtaining sensitive data such as passwords, usernames, credit card numbers.

The attacks often come in the form of instant messages or phishing emails designed to appear legitimate. The recipient of the email is then tricked into opening a malicious link, which leads to the installation of malware on the recipient's computer. It can also obtain personal information by sending an email that appears to be sent from a bank, asking to verify your identity by giving away your private information.

Uncovering [phishing domains](#) can be done easily with SecurityTrails.

Rootkit is a collection of software tools that enables remote control and administration-level access over a computer or computer networks. Once remote access is obtained, the rootkit can perform a number of malicious actions; they come equipped with keyloggers, password stealers and antivirus disablers.

Rootkits are installed by hiding in legitimate software: when you give permission to that software to make changes to your OS, the rootkit installs itself in your computer and waits for the hacker to activate it. Other ways of rootkit distribution include phishing emails, malicious links, files, and downloading software from suspicious websites.



We know today that many servers storing data for websites use SQL. As technology has progressed, network security threats have advanced, leading us to the threat of SQL injection attacks.

SQL injection attacks are designed to target data-driven applications by exploiting security vulnerabilities in the application's software. They use malicious code to obtain private data, change and even destroy that data, and can go as far as to void transactions on websites. It has quickly become one of the most dangerous privacy issues for data confidentiality. You can read more on the history of [SQL injection attacks](#) to better understand the threat it poses to cybersecurity.

Man-in-the-middle attacks are cybersecurity attacks that allow the attacker to eavesdrop on communication between two targets. It can listen to a communication which should, in normal settings, be private.

As an example, a man-in-the-middle attack happens when the attacker wants to intercept a communication between person A and person B. Person A sends their public key to person B, but the attacker intercepts it and sends a forged message to person B, representing themselves as A, but instead it has the attacker's public key. B believes that the message comes from person A and encrypts the message with the attacker's public key, sends it back to A, but the attacker again intercepts this message, opens the message with their private key, possibly alters it, and re-encrypts it using the public key that was first provided by person A. Again, when the message is transferred back to person A, they believe it comes from person B, and this way, we have an attacker in the middle that eavesdrops the communication between two targets.

Here are just some of the types of MITM attacks:

- DNS spoofing
- HTTPS spoofing
- IP spoofing
- ARP spoofing
- SSL hijacking
- Wi-Fi hacking